NOTE 03 - THE MITRE ATT&CK MATRICES: ENTERPRISE, MOBILE AND ICS

MITRE ATT&CK is not one single table. It is published as three separate matrices, because the technology, the telemetry and the attacker goals are very different in each environment. Each matrix has its own tactics, techniques and IDs, and the three must never be mixed up.

1. Enterprise matrix

- Covers: traditional and cloud IT - Windows, Linux, macOS, cloud platforms and services, network infrastructure, containers and identity providers.
- Used for: almost every corporate SOC, because this is where the office endpoints, servers, Active Directory, Microsoft 365 and AWS/Azure workloads live.
- Tactics: Reconnaissance, Resource Development, Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact.
- Typical techniques: phishing attachments, PowerShell, LSASS dumping, RDP lateral movement, scheduled tasks, data encrypted for impact.
- Who uses it: SOC L1/L2 analysts, detection engineers, threat hunters, red teams and incident responders in IT environments.

2. Mobile matrix

- Covers: Android and iOS devices, including the apps running on them.
- Why it exists: a phone has no "registry Run key" and no `lsass.exe`; attackers use completely different behaviour such as abusing accessibility services, abusing legitimate app permissions, or installing profiles.
- Tactics: Initial Access, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact.
- Typical techniques: malicious apps, abuse of Android `accessibility` services to read screens, SMS/notification interception, abusing enterprise MDM profiles.
- Who uses it: mobile threat defence teams, MDM administrators, and SOCs that monitor bring-your-own-device fleets or mobile banking apps.

3. ICS matrix

- Covers: industrial control systems - SCADA, PLCs, RTUs, engineering workstations and the networks connecting them (manufacturing, water, energy, transport).
- Why it is separate: in ICS the priority is safety and availability of physical processes, so losing a workstation matters far less than losing control of a turbine. Many IT controls cannot be installed at all on old PLCs.
- Tactics: Initial Access, Execution, Persistence, Privilege Escalation, Evasion, Discovery, Lateral Movement, Collection, Command and Control, Inhibit Response Function, Impair Process Control, Impact.
- Typical techniques: unauthorised command messages to a PLC, manipulation of view (hiding what the operator sees), denial of service on the HMI, firmware tampering.
- Who uses it: OT/ICS security teams, plant engineers and critical infrastructure SOCs.

Comparison

Aspect	Enterprise	Mobile	ICS
Protects	IT endpoints, servers, cloud, network, identity	Android and iOS devices and apps	Industrial control and OT systems
Main concern	Confidentiality and integrity of business data	Device data, SMS, location, app credentials	Physical safety and process availability
Example tactic unique to it	Resource Development	(shares most IT tactics)	Inhibit Response Function, Impair Process Control
Example technique	T1059 Command and Scripting Interpreter	Abuse of accessibility services	Unauthorised command message
Typical SOC owner	Corporate SOC	Mobile/MDM security team	OT/ICS SOC or plant engineering
Extra environment	Sub-matrices for Windows, Linux, macOS, Cloud, Network, Containers, IaaS/SaaS/Office	Android and iOS specific tables	Pre-ICS plus the ICS matrix

Which one should an analyst open?

1. Ask what asset raised the alert.
2. Laptop, server, cloud workload, domain controller -> Enterprise.
3. Phone or tablet - or an app on one -> Mobile.
4. PLC, HMI, historian, engineering workstation, plant network -> ICS.
5. Then map the observed behaviour to the tactic and technique inside that matrix - the same word can carry a different ID in a different matrix.

Key points to remember

- Three matrices, three vocabularies - Enterprise (IT), Mobile (phones), ICS (industrial).
- IDs are not interchangeable between matrices.
- Enterprise is the day-to-day matrix for a normal SOC; Mobile and ICS exist because those environments have different behaviour, different log sources and different priorities.
- In ICS the impact tactic is about physical consequences, not just stolen data.